IS Audit & Control

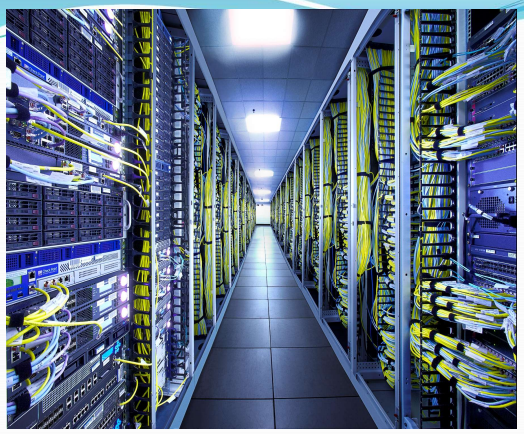
Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Data Centers and Disaster Recovery

Objectives

- Physical security and environmental controls
- Data center operations
- System and site resiliency
- Disaster preparedness



NTT Japan Data Center

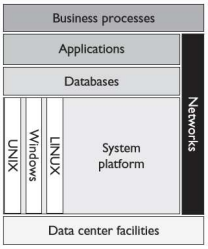


Data center

- A **data center** (sometimes spelled **datacenter**) is a centralized repository, either physical or virtual, for the storage, management, and dissemination of **data** and information organized around a particular body of knowledge or pertaining to a particular business.

Data-processing hierarchy

- Figure shows the relationships among data center facilities, system platforms, databases, applications, and business processes.



Major data center threats

- • Natural threats such as weather events, flooding, earthquakes, and fire
- • Manmade threats such as terrorist incidents, riots, theft, and sabotage
- • Environmental hazards such as extreme temperatures and humidity
- • Loss of utilities such as electrical power and telecommunications

Physical Security & Environmental Controls

Physical Security & Environmental Controls

- Data centers incorporate several types of facility-based controls, commonly referred to as physical security and environmental controls, including facility access control systems, alarm systems, and fire suppression systems. These systems are designed to prevent unauthorized intrusion, detect problems before they cause damage, and prevent the spread of fire.

Facility Access Control Systems

- Facility access control systems authenticate workers prior to providing physical entry to facilities, with the goal of protecting the information systems that reside within the data center.
- Physical access control systems use authentication based on something you know, something you have, or something you are.

Facility Access Control Systems

- **Man-traps** consist of two doors that are separated by a corridor or a small closet sized room. People entering the facility must first authenticate to open the door that allows them to enter the corridor. Once the first door closes behind them, they must authenticate again to open the door leading to the data center facility. The two doors cannot be open at the same time. Even if someone is able to circumvent security and gain access to the corridor via the first door, the person will be effectively trapped when the access control system blocks his or her access to the data center itself.

Alarm Systems

- Burglar alarms (magnetic door, window, or cabinet sensors; motion sensors; audio sensors)
- Fire alarms (heat and/or smoke-activated sensors broken into zones that cover different parts of facility)
- Water alarms (usually with sensors beneath the raised floor, near bathrooms, or in water pipe ducts)
- Humidity alarms (normally with sensors disbursed throughout the facility)
- Power fluctuation alarms (with sensors near the logical point of entry)
- Chemical or gas alarms (sometimes in battery rooms and near air intakes - usually with sensors beneath the raised floor, near bathrooms, or in water pipe ducts)

Fire Suppression Systems

- Because of the large amount of electrical equipment, fire is a major threat to data centers. Therefore, data centers normally are equipped with sophisticated fire-suppression systems and should have a sufficient number of fire extinguishers. Generally speaking, fire-suppression systems come in two varieties: water-based systems and gas-based systems.

System and Site Resiliency

- Because the computer systems that reside in a data center are leveraged to automate business functions, they must be **available any time** the business operates. Therefore, data centers incorporate various types of controls to ensure that systems remain available to perform critical business operations. These controls are designed to protect power, the computing environment, and wide area networks (WANs).

System and Site Resiliency

- Power : Clean power is critical to maintain computer operations. Power fluctuations such as spikes, surges, sags, brown-outs, and black-outs can damage computer components or cause outages. To mitigate this risk, data centers provide power redundancy in several layers, including the following:
  - Redundant power feeds (connecting data center to more than one power grid)
  - Ground to earth (to carry power away from critical components during fault conditions)
  - Power conditioning (flatten harmful spikes & sags in current)
  - Battery backup systems or UPSs (provide uninterrupted power for power fluctuations, brown-outs, black-outs)
  - Generators (provide power during prolonged power outages)

System and Site Resiliency

- **Heating, Ventilation, and Air Conditioning (HVAC):** Extreme temperature and humidity conditions can cause damage to computer systems. Because computers require specific environmental conditions to operate reliably, HVAC systems are required controls. Data centers typically provide sophisticated redundant systems to maintain constant temperature and humidity and often provide double the required capacity.

System and Site Resiliency

- **Network Connectivity :**Whether from internal networks or the Internet, users access information systems residing within data center facilities through network connections. Network connectivity is critical. More often than not, data center facilities have redundant Internet and WAN connections via multiple carriers. If one carrier experiences a network outage, service to the facilities can be provided by another carrier.

System and Site Resiliency

- **Data Center Operations:** Although data centers are designed to be automated, they do require a staff to operate. As a result, data center operations should be governed by policies, plans, and procedures. The auditor should expect to find the following areas covered by policies, plans, and procedures:
  - Physical access control
  - System and facility monitoring
  - Facility and equipment planning, tracking, and maintenance
  - Response procedures for outages, emergencies, and alarm conditions

System and Site Resiliency

- Disaster Preparedness All data centers are susceptible to natural and manmade disasters. History shows that when disaster strikes a data center, the organizations such facilities serve come to a screeching halt. The auditor's job is to identify and measure physical and administrative controls at the facility that mitigate the risk of data-processing disruptions, including the following:
  - System resiliency
  - Data backup and restore
  - Disaster recovery planning

Steps for Auditing Data Centers

- Neighborhood and external risk factors
- Physical access controls
- Environmental controls
- Power and electricity
- Fire suppression
- Data center operations
- System resiliency
- Data backup and restore
- Disaster recovery planning

Auditing Data Centers

- **1. Review exterior lighting, building orientation, signage, fences, neighborhood for facility risks.**
  - Barriers are in place to prevent cars from getting too close to the building.
  - **Floor** of the building : The ideal is a single-story data center that is 5 feet or so above ground.
  - **Signage** Review exterior / interior signage for anonymity. It will reduce possibility of espionage, theft, sabotage. Don't guide visitors to data center via signage.
  - **Neighborhood:** Ideal is a standalone structure without close neighbors. E.g, multitenant building issues, close to a warehouse or manufacturing facility etc.
  - **Exterior Lighting:** walls / parking lots illuminated uniformly that allows viewing at a reasonable distance.
  - **Fences:** 3- to 4-foot fence will deter common trespassers. An 8-foot fence with barbed wire at the top will deter all and most determined intruders.

Auditing Data Centers

- **2. Research location for environmental hazards & to determine distance to emergency services.**
  - Flood elevations
  - Weather and earth movement threats
  - Proximity to transportation-related hazards (Planes, trains, and automobiles are risk to data center operations.)
  - Local crime rate: if high, reinforced fences, increased security personnel, CCTV, and perimeter alarm systems.
  - Proximity to industrial areas
  - Proximity to emergency services

Auditing Data Centers

- **3. Review data center doors and walls.**
  - Use either raised floors or drop ceilings to conceal ventilation ducts and power and network cables.
  - **Doors** : must be force-resistant, magnetic locks.
  - Review the location of each door's **hinges**. Why ?
    - If hinges outside the room, intruder may remove the door by popping it off its hinges.
  - Verify that **man-traps** exist and are working properly.
  - **Windows:** constructed with shatterproof glass. Windows looking in on the data center should be avoided.



Auditing Data Centers

- 4. Evaluate physical authentication devices to determine whether they are appropriate and are working properly.
  - Restricts access based on individual's access needs or to particular doors or to particular hours of the day.
  - Deactivated in the event an employee is terminated or changes jobs or a key/card/badge is lost or stolen.
  - Difficult to duplicate or steal credentials
- **Card-Key and Proximity Devices:** use magnetic stripes or RFID chips to authenticate users who possess the card. Because a stolen card can be used for unauthorized authentication, a PIN-code device will preferably be coupled with the card-key reader. Verify that all card-key readers are working properly and are logging access attempts.

Auditing Data Centers

- **Biometric Devices:** more accurate and cost-effective. Able to measure fingerprint, retina, and hand geometry. Devices are difficult to defeat. Review the quality of the biometric system being used to determine whether an inordinate number of false negatives or any observed false positives have occurred.
- **Key Locks and Combination Locks:** Weakest forms of physical authentication and should be avoided. These forms of physical authentication offer no way to identify who has access to the data center. Keys can be lost, stolen, borrowed, or copied.

Auditing Data Centers

- 5. Ensure that physical access control procedures are comprehensive and being followed by data center and security staff.
  - Ensure that access authorization requirements are documented and clearly defined for both employees and guests. The philosophy of "**minimum necessary access**" should be embraced.
  - Verify that **guest access procedures** include restrictions on taking pictures. Visitors should be required to sign a visitor log and should be required to wear identification badges that are a different color from employee badges.
  - Review a sample of both guest access and employee ID authorization requests to ensure that access control procedures are followed.

Auditing Data Centers

- Review procedures for ensuring that data center access is removed when it is no longer required. Look for termination checklist; it should be automated.
- Determine whether **management regularly reviews** the physical access authorizations for validity. Management should periodically pull a list of people with data center access and review it for appropriateness. Review evidence that this is happening.

Auditing Data Centers

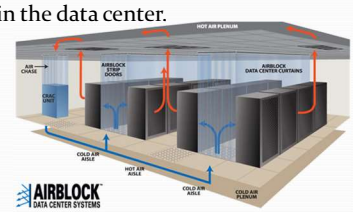
- 6. Ensure that burglar alarms and surveillance systems are protecting the data center from physical intrusion.
  - Review the **placement** of intrusion sensors:
  - **Motion sensors** that detect infrared motion
  - **Contact sensors** that are placed on windows and doors to detect when they are opened or broken
  - **Audio** sensors to detect breaking glass or changes in normal ambient noise
  - **Door prop** alarms to detect when a data center door is left open for more than a specified length of time (typically 30 seconds).

Auditing Data Centers

- 7. Review security guard **building round logs** and other documentation to evaluate the effectiveness of the security personnel function.
  - Verify that documentation of building rounds, access logs, and incident logs/reports exist.
- 8. Verify that sensitive areas of data center are secured. Computer processing equipment essential to data center operations (such as hardware systems and power supply breakers) is located within a secure area.
  - Sensitive : power supplies, HVAC equipment, batteries, production servers, staging servers , generators etc.
  - process sensitive information may be locked within a cage or cabinet, with only a select number of personnel given access.

Auditing Data Centers

- 9. Verify that HVAC systems maintain constant temperatures within the data center.



  - temperatures should range 65 to 70°F.
  - humidity levels 45% and 55%.
  - Ensure that sensors are placed in appropriate locations.
  - Look for cold aisle and warm aisle configuration, which is a configuration of equipment racks where servers are faced such that hot and cold air are separated, thereby improving cooling efficiency.

Auditing Data Centers

- 10. Ensure that a water alarm system is configured to detect water in high-risk areas of the data center.
  - Review maintenance records to ensure that the alarm system is maintained periodically.
  - Floor plans indicating shut off valves for all water systems should be available.
  - Data center managers should be aware of all water valves within the secured area.
- 11. Determine whether the data center has redundant power feeds.

Auditing Data Centers

- 12. Verify that ground-to-earth exists to protect computer systems.
  - Ground-to-earth is a basic feature of all electrical installations that consists of a green wire that connects all electrical outlets to a rod that is sunk into the ground. When short circuits or electrical faults occur, excess voltage is passed through the ground wire safely into the ground rather than short-circuiting electrical equipment.
- 15. Ensure that generators protect against prolonged power loss and are in good working condition.
  - **Diesel generators** : common, finite amount of fuel stored in their tanks. fuel is also a biohazard. Spillage could result in significant cleanup expenses.
  - **Natural gas generators** run cleaner and theoretically have an infinite supply of fuel as long as the gas lines are intact. No danger of spills, fire danger is increased. Expensive.
  - **Propane** generators are also expensive but have a limited supply of fuel.

Auditing Data Centers

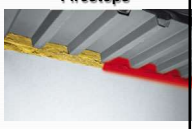
- 16. Evaluate the usage and protection of emergency power-off (EPO) switches.
  - EPO switches are designed to shut off power immediately to the computer and peripheral devices during emergencies.
  - Ensure that they are clearly labeled and easily accessible.
  - Secured from unauthorized or accidental usage.
  - Should be inside the secured area and underneath some sort of shield to prevent accidental activation.



Auditing Data Centers

- 17. Ensure that data center building construction incorporates appropriate fire suppression features.
  - **Fire-rated walls** and doors to prevent fire from moving from one area of a building to another
  - **Firestops** where fire-rated walls or floor assemblies are sealed to prevent the spread of fire
  - **Standpipe** fire hose systems to provide a ready supply of water for fire suppression

Firestops





Auditing Data Centers

- 18. Ensure that data center personnel are trained in hazardous materials (hazmat) handling and storage and that hazmat procedures are appropriate. Also determine whether data center personnel are trained in how to respond to a fire emergency.

Review hazmat incident reports and hazmat and fire response training materials and procedures, as well as interview data center staff.



Auditing Data Centers

- **19. Verify that fire extinguishers are strategically placed and are maintained properly.**
  - placed in hallways and aisles every 50 feet.
  - 3 types: dry chemical, water, and inert gas–based.
  - DC should use inert gas–based fire extinguishers (CO_2)
  - water and dry chemicals damage electrical equipment.
- **20. Ensure that fire suppression systems are protecting the data center from fire.**
  - 4 types of suppression systems:
  - **Wet pipe:** Pipes are always water-filled.(least desirable), because a leaky pipe would result in flooding.
  - **Dry pipe:** Pipes are filled with air and are filled with water at the time of a discharge.
  - **Preaction:** Pipes are filled at stage 1 activation and water is discharged during stage 2.
  - **Deluge** A dry pipe system that discharges a large amount of water to overwhelm a fire.

Auditing Data Centers

- **21. Verify that fire alarms are in place to protect the data center from the risk of fire.**
  - **Heat sensors** Activate when temperature reaches a threshold or when temperatures rise quickly.
  - **Smoke sensors** Activate when they detect smoke
  - **Flame sensors** Activate when they sense infrared energy or flickering of a flame.
- **22. Review the alarm monitoring console(s), reports, and procedures to verify that alarms are monitored continually by data center personnel.**
- **23. Verify that network, operating system, and application monitoring provides adequate information to identify potential problems for systems located in the data center.**

Auditing Data Centers

- **24. Ensure that roles and responsibilities of data center personnel are clearly defined.**
- **25. Verify that duties and job functions of data center personnel are segregated appropriately.**
- **26. Ensure that emergency response procedures address reasonably anticipated threats.**
- **27. Verify that data center facility-based systems and equipment are maintained properly.**
- **28. Ensure that data center personnel are trained properly to perform their job functions.**

Auditing Data Centers

- **29. Ensure that data center capacity is planned to avoid unnecessary outages.**
  - Capacity planning: forecast how much rack space, network drops, electricity, heating, ventilation, air conditioning, is needed for current & future operations.
- **30. Verify that procedures are present to ensure secure storage and disposal of electronic media.**
  - stored securely in dry, temperature-controlled manner.
  - sensitive information is encrypted and tracked as it moves from one location to another.
  - Electronic media is degaussed, overwritten with a DoD–compliant electronic shredding utility, or physically destroyed prior to disposal.

Auditing Data Centers

- **31. Review and evaluate asset management for data center equipment.**
  - Asset management is the controlling, tracking, and reporting of assets to facilitate accounting for the assets.
  - **Asset procurement process.**
  - **Asset tracking.**
  - **Current inventory of all equipment.**
  - **Asset move and disposal procedures.**
- **32. Ensure that hardware redundancy (redundancy of components within a system) is used to provide high availability where required.**

Auditing Data Centers

- **33. Verify that duplicate systems are used where very high system availability is required.**
  - duplicate (redundant) systems are used to provide for automatic failover in the event of a system crash.
  - 3 types of database transaction redundancy:
  - **Electronic vaulting** Provides periodic data copies through a batch process
  - **Remote journaling** Provides real-time parallel processing over a network connection
  - **Database shadowing** Provides real-time parallel processing over ***two or more*** network connections

Auditing Data Centers

- 34. Ensure that backup procedures and capacity are appropriate for respective systems.
- 35. Verify that systems can be restored from backup media.
- 36. Ensure that backup media can be retrieved promptly from off-site storage facilities.
- 37. Ensure that a disaster recovery plan (DRP) exists and is comprehensive and that key employees are aware of their roles in the event of a disaster.
- 38. Ensure that DRPs are updated and tested regularly.

Auditing Data Centers

- 39. Verify that parts inventories and vendor agreements are accurate and current.
- 40. Ensure that emergency operations plans address various disaster scenarios adequately.

Resource	Website
The Disaster Recovery Journal	www.drj.com
Disaster Recovery Institute International	www.drii.org
Disaster Recovery World	www.disasterrecoveryworld.com
ISACA	www.isaca.org